NMAP (NETWORK MAPPER) FOR CYBER-SECURITY

Metasploitable 2 — Nmap-led network VAPT

Prep ared for: SkillLogic Cybersecurity Program

Assessment date: 28 October 2026 (date visible in supplied evidence)

Lab: Kali Linux • Oracle VirtualBox • Metasploitable 2

Target: 192.168.29.72 | Scanner/callback host: 192.168.29.163

CONFIDENTIAL TRAINING REPORT — authorized lab only

MADISETTI NAGADITYA SHANMUKH

CYBER -SECURITY

Field	Value
Report title	Metasploitable 2 Nmap-led VAPT Report
Assessment type	Network vulnerability assessment with limited lab validation
Environment	Kali Linux and Metasploitable 2 VMs hosted in VirtualBox
Target IP	192.168.29.72
Scanner IP shown	192.168.29.163
Evidence	19 terminal screenshots
Limitations	Selected TCP ports; no full UDP scan, comprehensive authenticated audit or remediation retest shown

Contents

1. Executive Summary • 2. Scope and Rules of Engagement • 3. Methodology • 4. Nmap Procedures with command evidence • 5. Port and Service Inventory • 6. Summary of Findings • 7. CVE/CVSS Reference Table • 8. Detailed Findings • 9. Remediation and Retest Plan • 10. Conclusion • 11. References • Appendix A — Screenshot Evidence

1. Executive Summary

This assessment reviewed the intentionally vulnerable Metasploitable 2 VM from Kali Linux. Nmap confirmed the target was up and identified a broad exposed TCP service surface. Version detection identified multiple legacy services. Focused NSE checks reported anonymous FTP access allowed; SMB script output reported message signing disabled. Separate screenshots show successful SSH authentication for msfadmin and a Metasploit session associated with the vsftpd 2.3.4 backdoor module.

Overall lab risk: CRITICAL. This is a judgement for the deliberately vulnerable training image, not a CVSS score or a rating of a production system.

2. Scope and Rules of Engagement

In scope: only Metasploitable 2 at 192.168.29.72 on the local VirtualBox lab network. Supplied evidence shows Kali at 192.168.29.163. Do not scan systems outside this authorized lab.

Out of scope: production systems, public IPs, denial-of-service testing, persistence, data destruction, and systems without written authorization. Keep the intentionally vulnerable VM isolated.

3. Methodology

The workflow follows the supplied sample report structure: scope/tools, summary of findings, detailed vulnerability entries, remediation and evidence. Nmap is the primary discovery tool; Metasploit/manual screenshots are secondary validation.

Phase	Procedure	Output / record
1. Discovery	nmap -sn	Host-up status
2. Port scan	nmap -sS	Open TCP ports
3. Fingerprinting	nmap -sV and nmap -O	Service banners and best-effort OS estimate
4. NSE checks	nmap -sC -sV and focused FTP scripts	Script findings
5. Evidence	-oN output and screenshots	Reproducible record
6. Correlation	Compare versions to NVD/vendor advisories	CVE applicability and confidence
7. Remediation	Fix and repeat scans	Before/after evidence

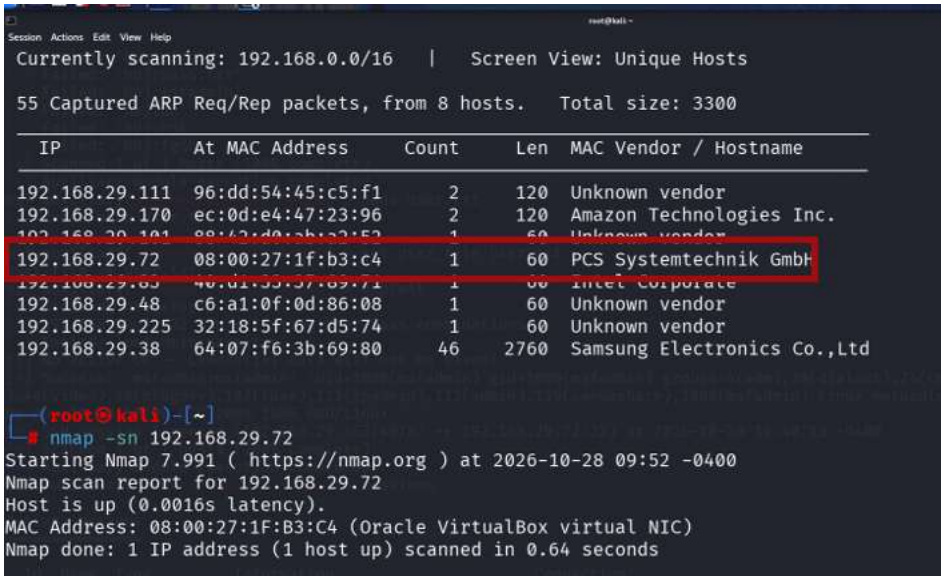
4. Nmap Procedures — Step by Step

Run only against the authorized lab target. Capture each command and complete output.

Step 1 — Confirm host reachability

```
nmap -sn 192.168.29.72
```

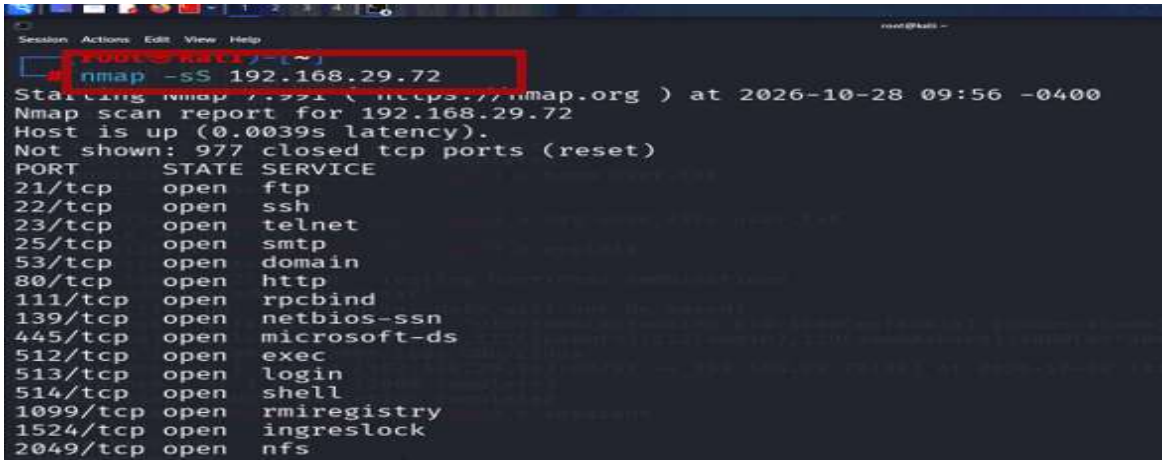
Command evidence: Evidence: host discovery / target identified on the lab network.



Purpose: host discovery without a port scan. Evidence: the supplied output says the host is up and identifies a VirtualBox virtual NIC. This command does not identify open ports.

Step 2 — Enumerate TCP ports

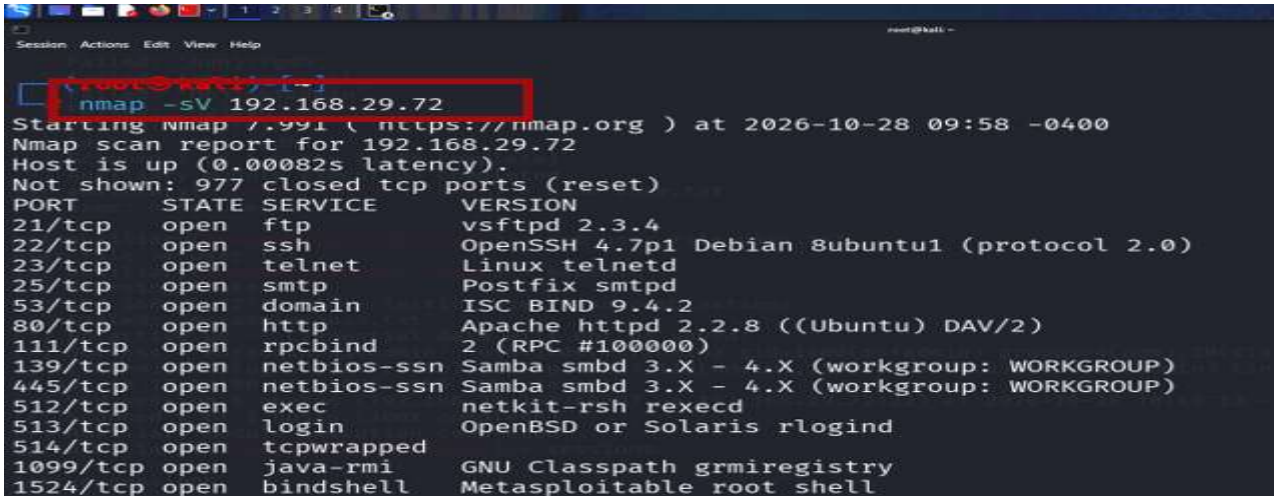
Command evidence: Evidence: TCP SYN scan and open-port inventory.



Purpose: TCP SYN scan of Nmap's default common TCP ports. Record the open ports and note that the output says 977 closed TCP ports were not shown. This is not an all-ports scan.

Step 3 — Identify service versions

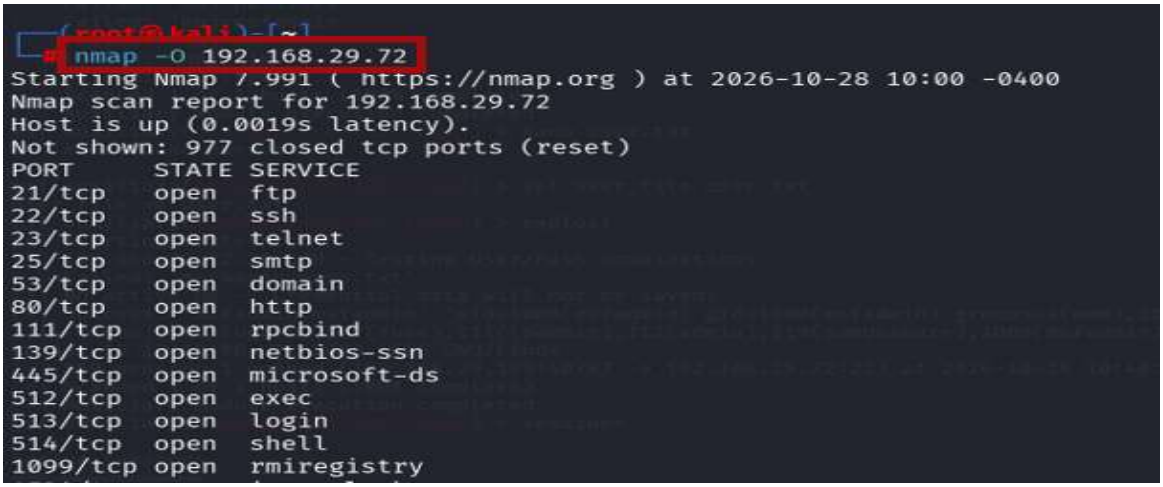
Command evidence: Evidence: service and version detection output.



Purpose: probe open services for product/version banners. Supplied output identifies vsftpd 2.3.4, OpenSSH 4.7p1, Apache 2.2.8, Samba and MySQL 5.0.51a among others. Banners are clues; they do not alone prove every associated CVE is exploitable.

Step 4 — Attempt OS fingerprinting

Command evidence: Evidence: OS-detection attempt; treat OS fingerprinting as an estimate.

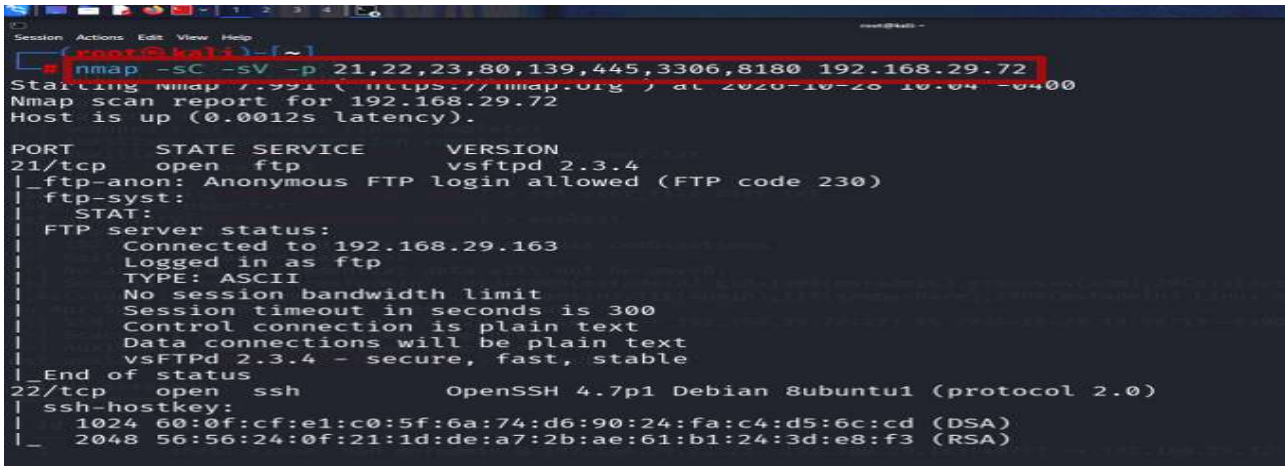


Purpose: infer the target operating system from network responses. Record this as an estimate. The screenshot shows the port inventory but does not provide enough clear OS fingerprint text to claim a definitive OS-detection result.

Step 5 — Run selected-port default scripts and version --detection

`nmap -sC -sV -p 21,22,23,80,139,445,3306,8180 192.168.29.72`

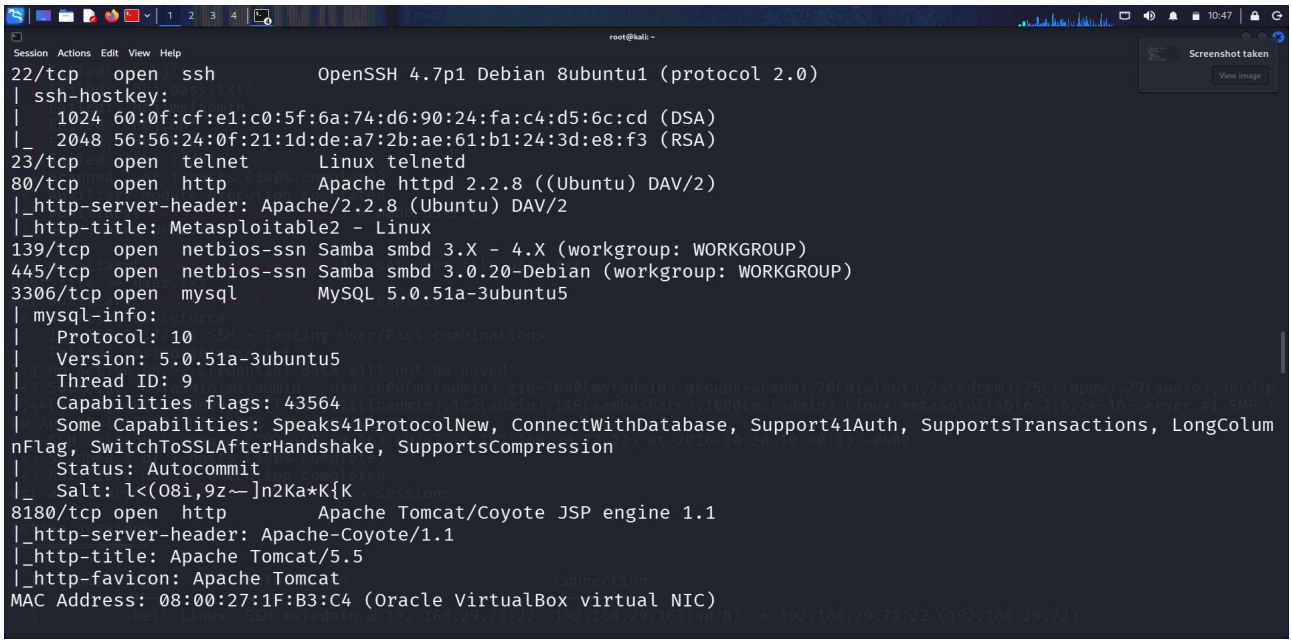
Command evidence: Evidence 1: selected-port NSE results, including FTP and SSH details.



```
Session Actions Edit View Help
┌──(root㉿kali)-[~]
└─# nmap -sC -sV -p 21,22,23,80,139,445,3306,8180 192.168.29.72
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-28 10:04 -0400
Nmap scan report for 192.168.29.72
Host is up (0.0012s latency).

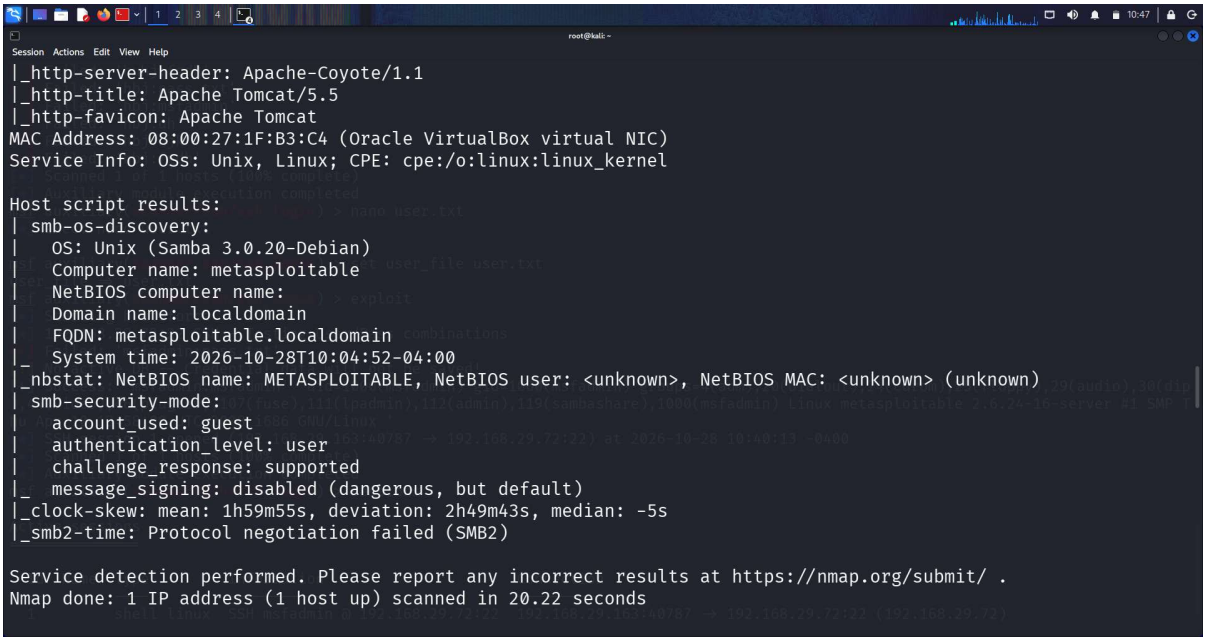
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.29.163
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
```

Command evidence: Evidence 2: continued service-script output.



```
Session Actions Edit View Help
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 9
|   Capabilities flags: 43564
|   Some Capabilities: Speaks41ProtocolNew, ConnectWithDatabase, Support41Auth, SupportsTransactions, LongColum
nFlag, SwitchToSSLAfterHandshake, SupportsCompression
|   Status: Autocommit
|_  Salt: l<(O8i,9z~_]n2Ka*K{K
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
MAC Address: 08:00:27:1F:B3:C4 (Oracle VirtualBox virtual NIC)
```

Command evidence: Evidence 3: HTTP, SMB and database service details.

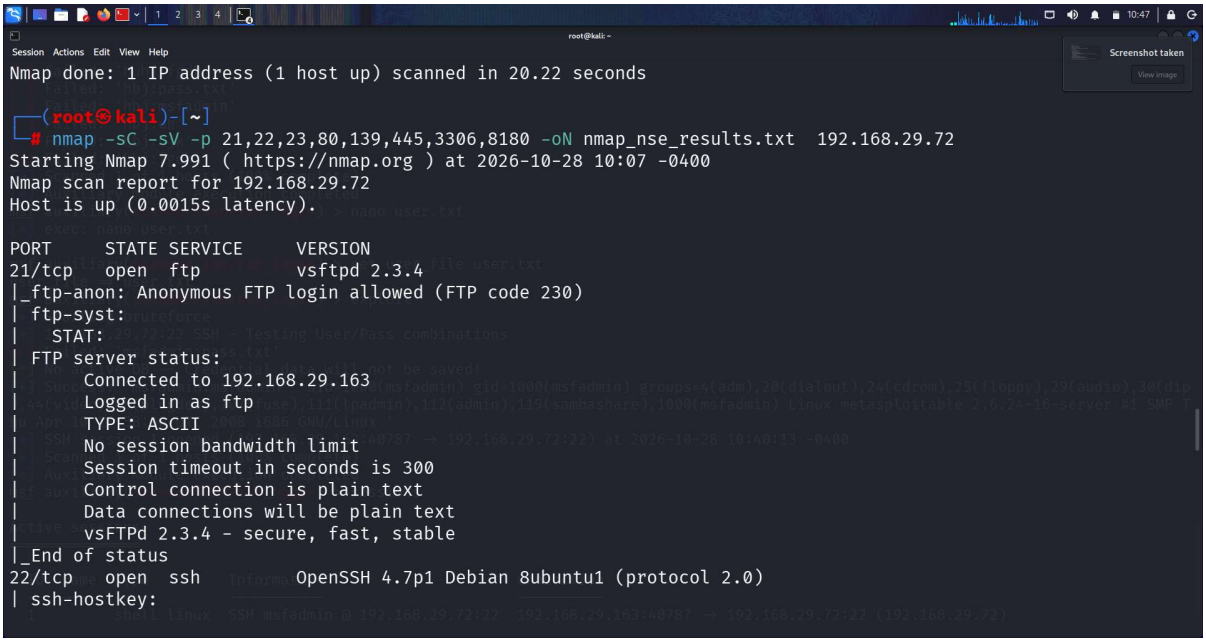


Purpose: run Nmap's default NSE scripts and version detection against the selected services. The screenshot reports anonymous FTP login allowed, SSH host-key information, HTTP headers/title, SMB details and MySQL information.

Step 6 — Save a reproducible record

`nmap -sC -sV -p 21,22,23,80,139,445,3306,8180 -oN nmap_nse_results.txt 192.168.29.72`

Command evidence: Evidence: command execution and saved output file record.

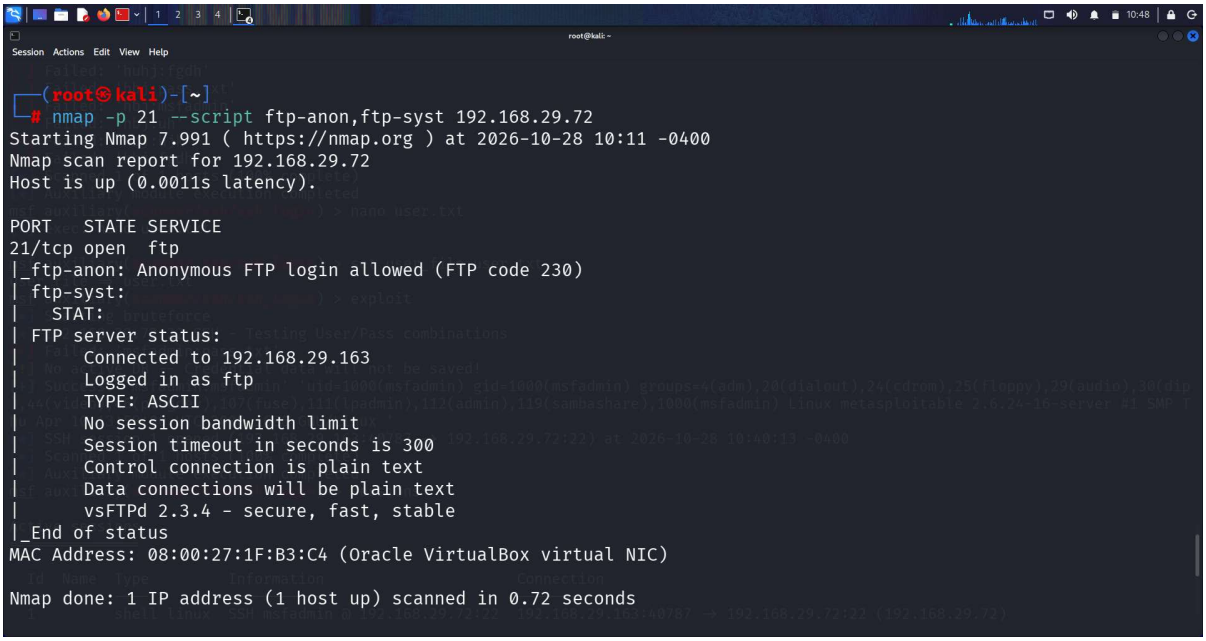


Purpose: store human-readable output in nmap_nse_results.txt. Keep this file with the screenshots and report. The supplied screenshot shows the command being run; the file contents themselves were not supplied separately.

Step 7 — Focused FTP checks

`nmap -p 21 --script ftp-anon,ftp-syst 192.168.29.72`

Command evidence: Evidence: focused FTP scripts report anonymous FTP login allowed.



Purpose: specifically check anonymous FTP access and gather FTP system information. Evidence shows “Anonymous FTP login allowed (FTP code 230)”.

Step 8 — Correlate and prioritize

Procedure: compare the detected service/version against NVD/vendor advisories; check affected-version ranges and configuration prerequisites.

Purpose: use a CVE only where version and conditions are relevant. A detected banner is not enough to assert every CVE for that product.

Step 9 — Remediate and retest

Procedure: apply the fixes in Section 9, then rerun equivalent Nmap commands.

Purpose: compare open ports, service versions and script findings before and after. A post-remediation retest is not included in the supplied screenshots.

5. Port and Service Inventory

Inventory transcribed from the supplied Nmap screenshots. Banner-based version matches are leads, not proof of every CVE.

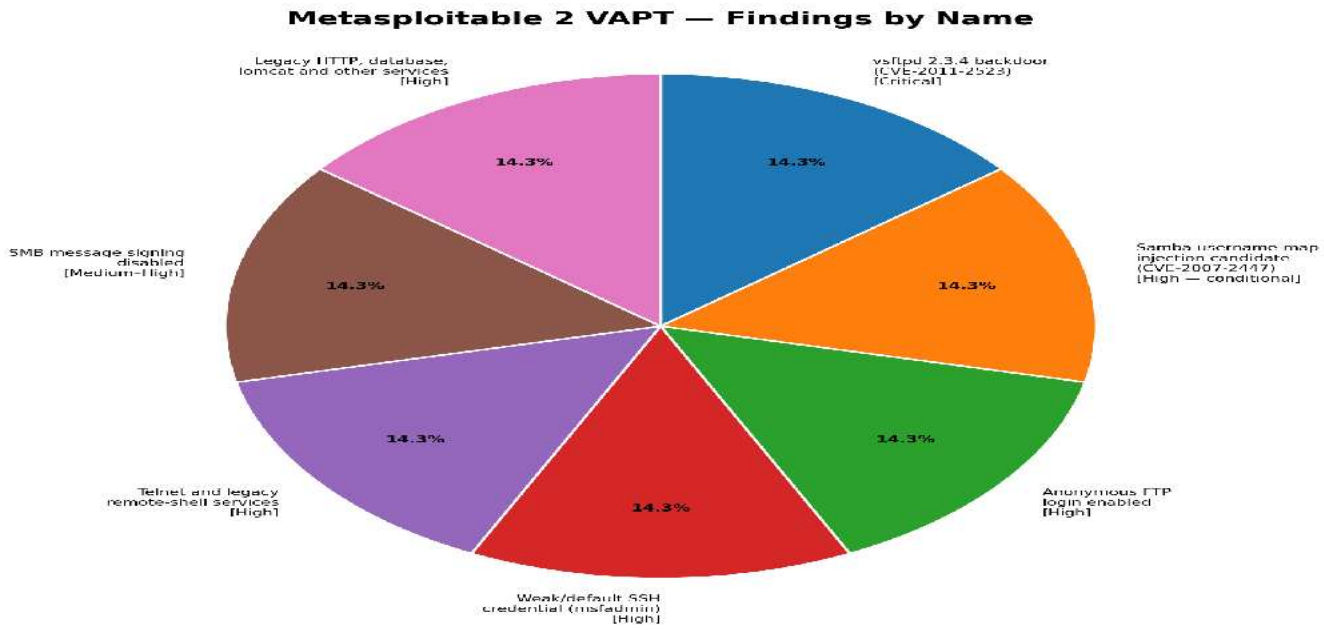
Port	Service / detected banner	Security significance
21/tcp	FTP — vsftpd 2.3.4	Anonymous login allowed; backdoor validation evidence discussed in F-01.
22/tcp	SSH — OpenSSH 4.7p1 Debian 8ubuntu1	Legacy version; successful msfadmin lab login is separate validation evidence.
23/tcp	Telnet — Linux telnetd	Plaintext remote administration protocol; disable/replace.
25/tcp	SMTP — Postfix smtpd	Review whether needed, patch level and relay policy.
53/tcp	DNS — ISC BIND 9.4.2	Legacy DNS software; review exposure and update.
80/tcp	HTTP — Apache 2.2.8 (Ubuntu) DAV/2	Legacy web server; inspect enabled methods and web apps.
111/tcp	rpcbind	Can disclose or support access to RPC services; restrict if unnecessary.

139/445/tcp	NetBIOS/SMB — Samba 3.x–4.x; 3.0.20-Debian shown	Legacy SMB/Samba; signing disabled reported by NSE.
512–514/tcp	exec / login / shell (legacy remote shell services)	Disable insecure legacy remote access.
1099/tcp	Java RMI registry	Restrict remote RMI access; review necessity.
1524/tcp	ingreslock; service label indicates Metasploitable root shell	High-risk exposed lab service; isolate host.
2049/tcp	NFS	Review exports and restrict client access.
2121/tcp	FTP — ProFTPD 1.3.1	Legacy FTP service; prefer encrypted transfer and upgrade.
3306/tcp	MySQL 5.0.51a-3ubuntu5	Legacy database; restrict network exposure and upgrade.
5432/tcp	PostgreSQL	Restrict access; exact version not visible in supplied excerpt.
8180/tcp	Apache Tomcat/Coyote 1.1; Tomcat 5.5	Legacy application server; restrict management interfaces and upgrade.

6. Summary of Findings

This table follows the sample report's summary format and lists every finding with name, severity, risk score and status. Published CVSS scores are labelled with their version; other 0–10 values are assessor-estimated prioritization scores for this training lab.

Finding Name	Severity	Risk Score	Status
vsftpd 2.3.4 backdoor (CVE-2011-2523)	Critical	9.8 (CVSS 3.1)	Lab validation shown; vulnerable banner observed
Samba username-map command injection candidate (CVE-2007-2447)	High — conditional	6.0 (CVSS v2 reference)	Candidate; required configuration not verified
Anonymous FTP login enabled	High	7.5 / 10 (assessed)	Confirmed by Nmap NSE; manual FTP login also shown
Weak/default SSH credential (msfadmin)	High	8.0 / 10 (assessed)	Confirmed in lab by separate SSH scanner evidence
Telnet and legacy remote-shell services exposed	High	7.5 / 10 (assessed)	Open ports observed by Nmap
SMB message signing disabled	Medium–High	6.5 / 10 (assessed)	Reported by SMB NSE output
Legacy HTTP, database, Tomcat and other services exposed	High	8.0 / 10 (assessed)	Legacy banners observed; specific CVEs need validation



7. CVE / CVSS Reference Table

CVE ID	Affected product / issue	CVSS / severity	Applicability to this lab	Evidence and caveat
CVE-2011-2523	vsftpd 2.3.4 backdoor; can open a shell on TCP/6200 in affected distribution builds.	9.8 / Critical (CVSS 3.1, NVD)	Strong candidate; lab validation screenshot reports a vsftpd 2.3.4 backdoor session.	Nmap banner reports vsftpd 2.3.4 on 21/tcp. NVD states the affected release condition is builds downloaded between 2011-06-30 and 2011-07-03. The screenshot's module result strengthens lab-specific validation, but package provenance is not documented.
CVE-2007-2447	Samba smbd command injection via username map script in affected configurations.	6.0 / CVSS 2.0 reference score	Candidate only; version banner Samba 3.0.20-Debian falls in the broad affected version range, but the required username map script configuration is not shown.	Do not mark confirmed until smb.conf / package patch status and prerequisites are checked. Oracle Linux advisory describes affected Samba 3.0.0 through 3.0.25rc3 and CVSS v2 score 6.0.

CVSS interpretation

CVSS v3.1: Critical 9.0–10.0, High 7.0–8.9, Medium 4.0–6.9, Low 0.1–3.9. CVSS v2 uses different conventions; CVE-2007-2447's 6.0 is explicitly a CVSS v2 reference score.

Why other services have no CVE number here

The screenshots do not establish exact package patch status or all enabled modules/configuration details for Apache, OpenSSH, BIND, MySQL, Tomcat and other services. Verify exact builds against vendor advisories and NVD before assigning more CVEs.

8. Detailed Findings

F-01 — vsftpd 2.3.4 backdoor

Severity: CRITICAL

Evidence: Nmap -sV reports vsftpd 2.3.4 on TCP/21. The focused FTP NSE script reports anonymous login allowed. Separate supplied Metasploit output says the target appears vulnerable and that a session opened. NVD documents CVE-2011-2523 for affected vsftpd 2.3.4 builds.

Impact: remote unauthenticated command execution/backdoor access may permit compromise of confidentiality, integrity and availability. The NVD CVSS 3.1 base score is 9.8 Critical.

Recommendation: disable FTP if unnecessary; remove the vulnerable build; install a supported, trusted package; verify package integrity; review logs and rebuild the VM from a trusted image if compromise is suspected. Keep this lab VM isolated.

Reference: https://nvd.nist.gov/vuln/detail/CVE-2011-2523

F-02 — Samba command injection candidate (CVE-2007-2447)

Severity: HIGH / CONDITIONAL

Evidence: Nmap reports Samba 3.x–4.x and a Samba 3.0.20-Debian banner on TCP/445. The exact smb.conf setting required by CVE-2007-2447 is not included in the screenshots.

Impact: if the affected version and vulnerable username map script configuration are both present, remote command execution may be possible.

Recommendation: verify package patch status and smb.conf; if applicable, upgrade Samba to a supported version, remove unsafe username-map script configuration, restrict SMB to trusted networks, and require signing where supported.

Reference: https://linux.oracle.com/cve/CVE-2007-2447.html

F-03 — Anonymous FTP access enabled

Severity: HIGH

Evidence: Nmap NSE output says anonymous FTP login allowed (FTP code 230). A separate manual FTP login also succeeds in the lab.

Impact: files placed in public FTP areas may be disclosed or altered depending on permissions; FTP traffic is not encrypted by default.

Recommendation: disable anonymous access unless explicitly required; audit permissions and files; replace FTP with SFTP or HTTPS; restrict TCP/21 to trusted hosts.

F-04 — Weak/default SSH credential

Severity: HIGH

Evidence: the separate SSH scanner screenshot shows successful authentication for account msfadmin against target TCP/22. This is a lab credential result, not a claim that every account is weak.

Impact: an attacker with the same credentials could authenticate remotely and potentially access the account's privileges.

Recommendation: change default credentials, remove unused accounts, use SSH keys or strong unique passwords, restrict management access by firewall, and monitor authentication logs.

F-05 — Legacy plaintext remote administration services

Severity: HIGH

Evidence: Nmap shows TCP/23 Telnet and TCP/512–514 legacy remote shell services open.

Impact: plaintext protocols may expose credentials/session contents and increase remote-access attack surface.

Recommendation: disable Telnet, rexec, rlogin and rsh; use SSH with key-based authentication; restrict remote administration to a dedicated management network.

F-06 — SMB message signing disabled

Severity: MEDIUM–HIGH

Evidence: SMB NSE output reports message signing disabled and identifies Samba 3.0.20-Debian.

Impact: depending on network position and environment, unsigned SMB traffic can increase exposure to tampering/relay-style attacks.

Recommendation: upgrade Samba, require SMB signing where appropriate, disable SMBv1 where possible, and block TCP/139 and TCP/445 from untrusted segments.

F-07 — Legacy services and broad attack surface

Severity: HIGH

Evidence: Nmap identifies legacy Apache 2.2.8, OpenSSH 4.7p1, BIND 9.4.2, MySQL 5.0.51a and Tomcat 5.5, plus RPC/NFS and other services. Exact patch state is not established by banners alone.

Impact: unsupported software may contain known vulnerabilities, while unnecessary open services increase the attack surface.

Recommendation: inventory exact package builds; upgrade to vendor-supported releases; stop unused services; restrict databases, RMI, NFS and administration interfaces; apply host and network firewall rules.

9. Remediation and Retest Plan

Keep the vulnerable VM isolated. Do not claim remediation is complete until the changes are made and a follow-up scan is captured.

Priority	Remediation action	How to verify after the change
Immediate	Isolate the Metasploitable VM using an internal/host-only lab network; do not bridge it to	Review VirtualBox adapter mode and confirm the target is reachable only from the intended lab

	the internet or production.	hosts.
Immediate	Remove/disable vsftpd 2.3.4 or replace with a trusted supported package; disable anonymous FTP.	Repeat nmap -sV -p 21 and nmap -p 21 --script ftp-anon,ftp-syst. Confirm the old version/anonymous login is no longer present.
Immediate	Change default credentials such as msfadmin; remove unnecessary accounts.	Review account policy and SSH authentication logs; test only with authorized credentials.
High	Disable Telnet and legacy rexec/rlogin/rsh services.	Repeat nmap -sS and verify ports 23 and 512–514 are no longer open if services are not required.
High	Upgrade Samba and review SMB signing/SMB protocol configuration.	Run selected-port nmap scripts again; verify configuration from the host and firewall rules.
High	Upgrade Apache, OpenSSH, BIND, MySQL and Tomcat to supported vendor versions.	Run nmap -sV for banner comparison and verify actual package versions on the host.
High	Restrict NFS, RPC, RMI, databases and management ports to trusted hosts.	Scan from allowed and disallowed lab segments and compare reachable ports.
Medium	Keep baseline and post-fix evidence in separate dated folders.	Retain the command, date, target, raw -oN output, screenshots and concise before/after table.

Retest record template

Test date/time	Command	Expected secure result	Actual result / evidence ID	Status
To be completed	nmap -sS 192.168.29.72	Only required ports open		Not tested
To be completed	nmap -sV 192.168.29.72	No vulnerable legacy banners		Not tested
To be completed	nmap -p 21 --script ftp-anon,ftp-syst 192.168.29.72	Anonymous FTP disabled or service closed		Not tested

10. Conclusion

Nmap evidence confirms a reachable Metasploitable 2 host with many exposed TCP services and legacy banners. NSE confirms anonymous FTP login and provides SMB configuration evidence. Separate Metasploit evidence supports the lab-specific vsftpd backdoor finding, while SSH scanner output supports the weak-credential finding. CVEs are limited to one strong vsftpd association and one conditional Samba candidate; additional CVEs require exact package/configuration validation.

No remediation retest was supplied; recommendations remain proposed actions until validated.

11. References

NVD CVE-2011-2523: https://nvd.nist.gov/vuln/detail/CVE-2011-2523

Oracle Linux CVE-2007-2447: https://linux.oracle.com/cve/CVE-2007-2447.html

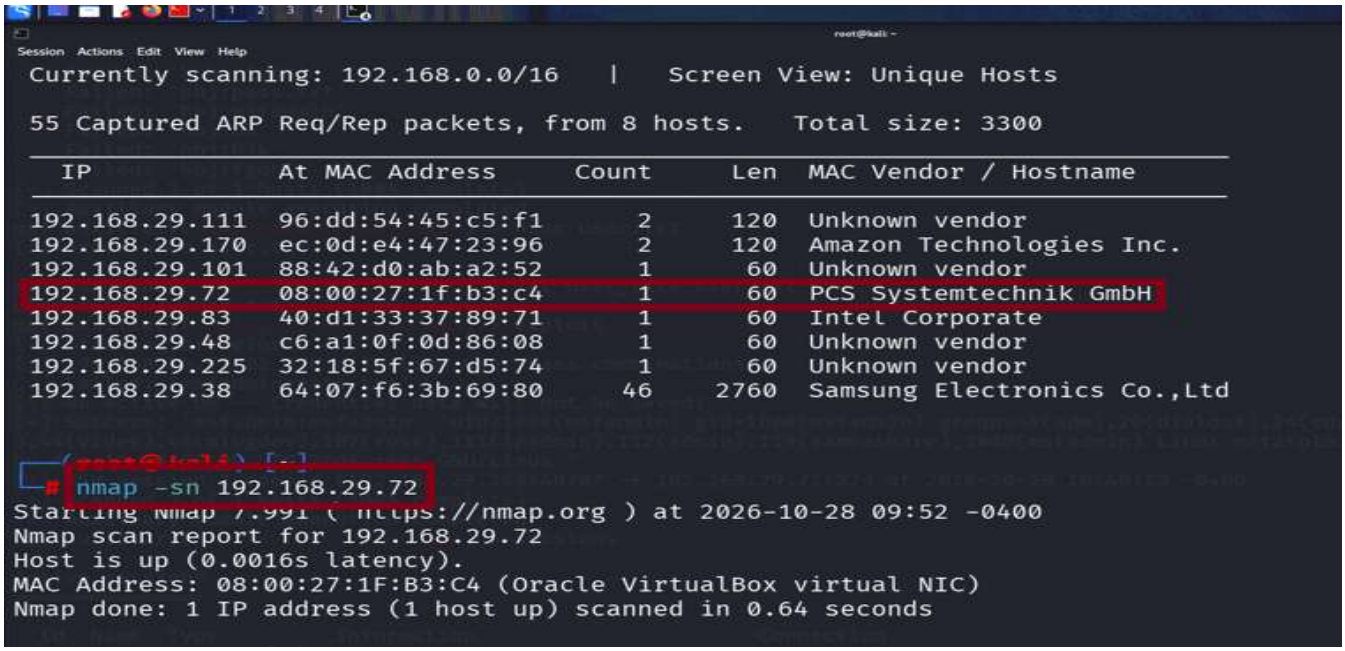
Apache HTTP Server 2.2 security notes: https://httpd.apache.org/security/vulnerabilities_22.html

Nmap reference guide: https://nmap.org/book/man.html

Appendix A1 — Nmap Discovery and Enumeration

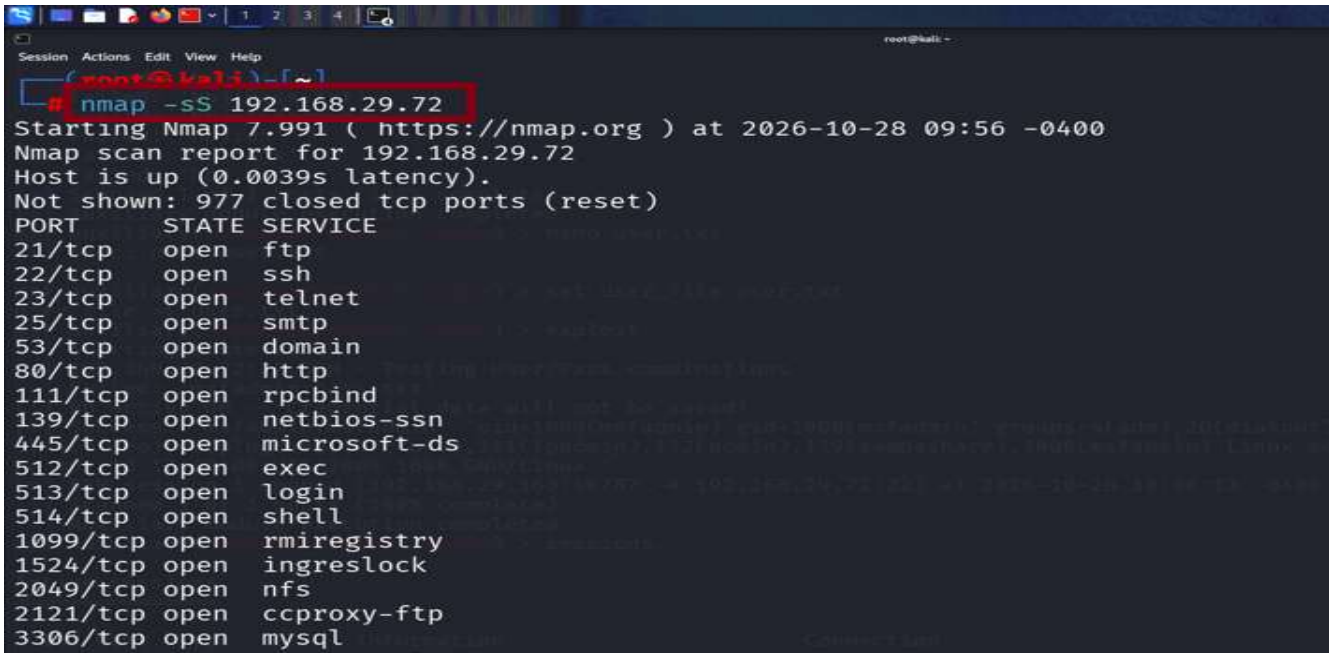
Evidence 01 — ARP host list and Nmap host check

The host list includes 192.168.29.72. The nmap -sn command reports the target host is up and shows a VirtualBox virtual NIC MAC.



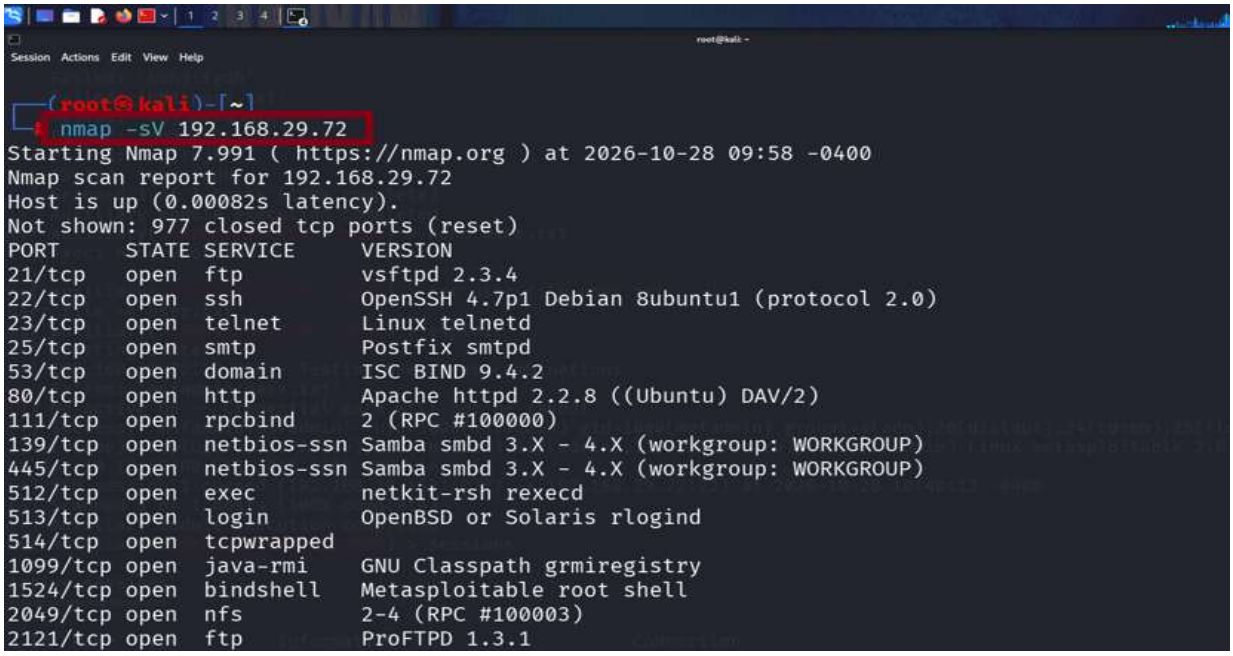
Evidence 02 — Nmap TCP SYN scan

The nmap -sS result enumerates multiple open TCP ports including FTP, SSH, Telnet, SMTP, DNS, HTTP, SMB and database services.



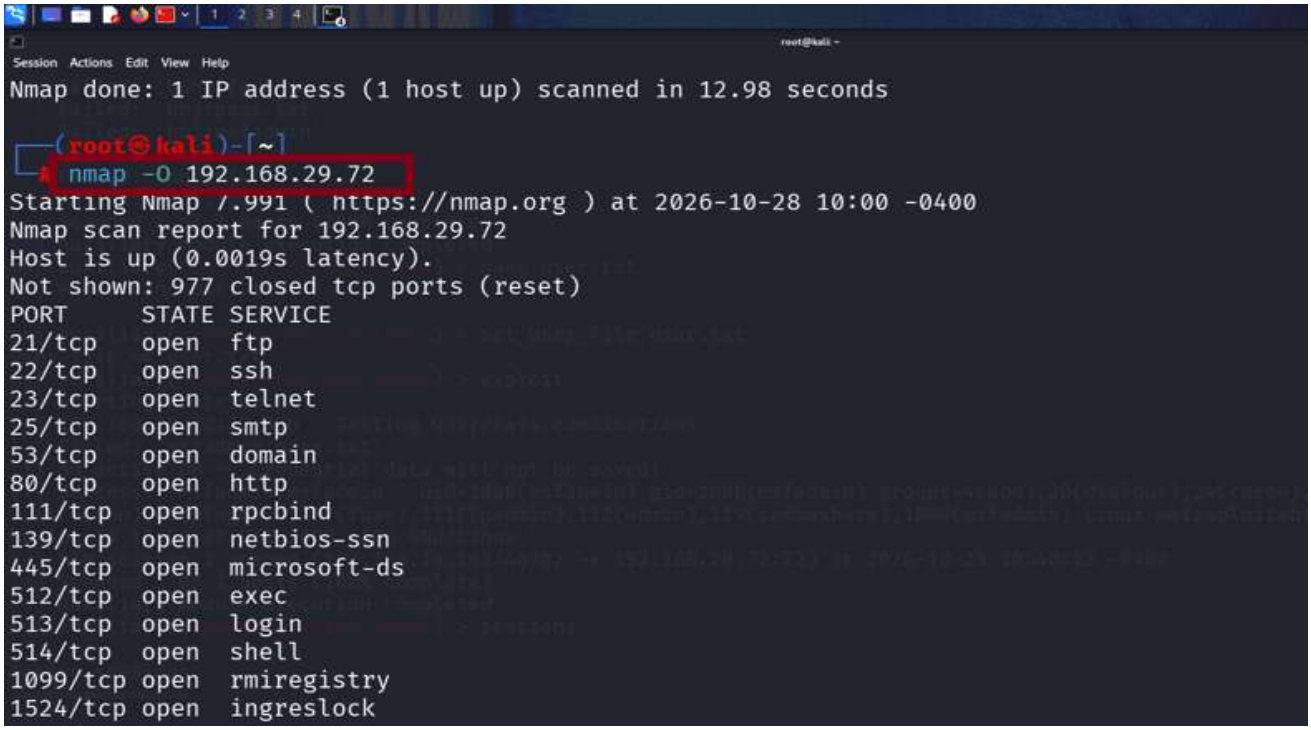
Evidence 03 — Nmap service/version detection

The nmap -sV result identifies legacy service banners such as vsftpd 2.3.4, OpenSSH 4.7p1, Apache 2.2.8 and Samba.



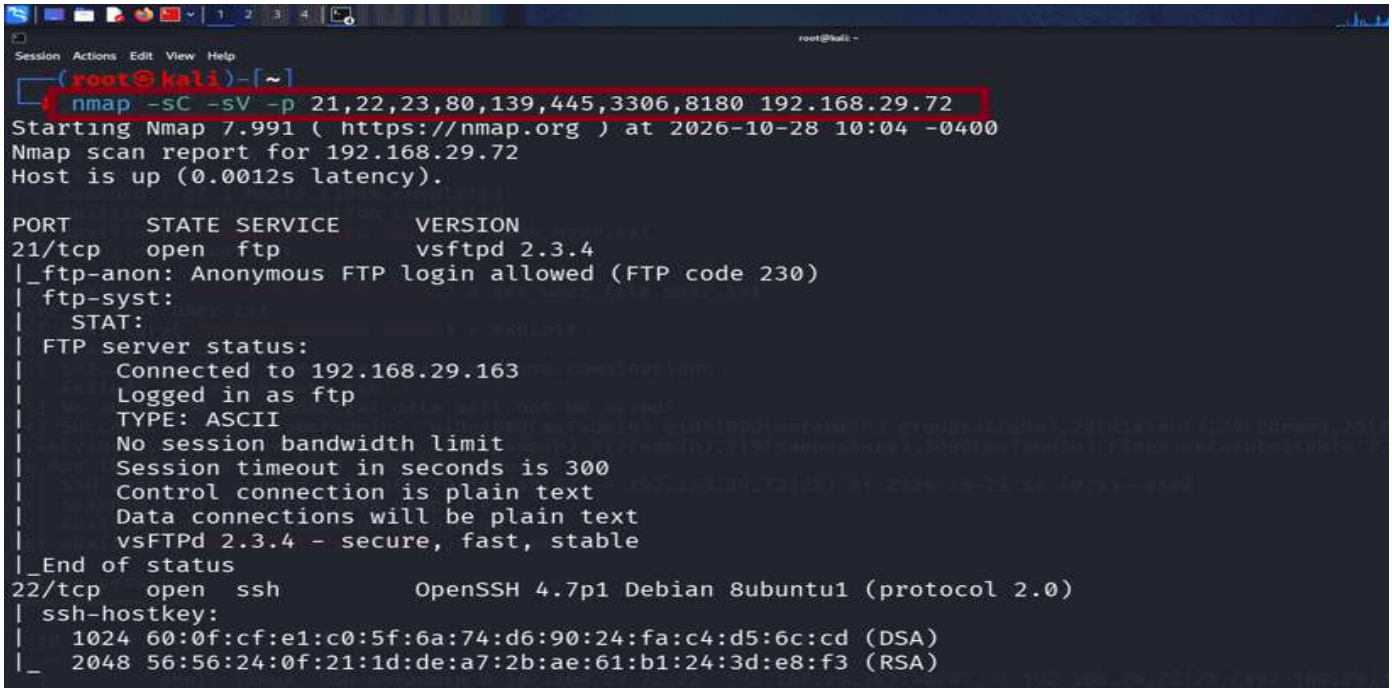
Evidence 04 — Nmap OS detection attempt

The screenshot shows the -O scan and port inventory. OS fingerprinting is best-effort and is not definitive proof of the operating system.



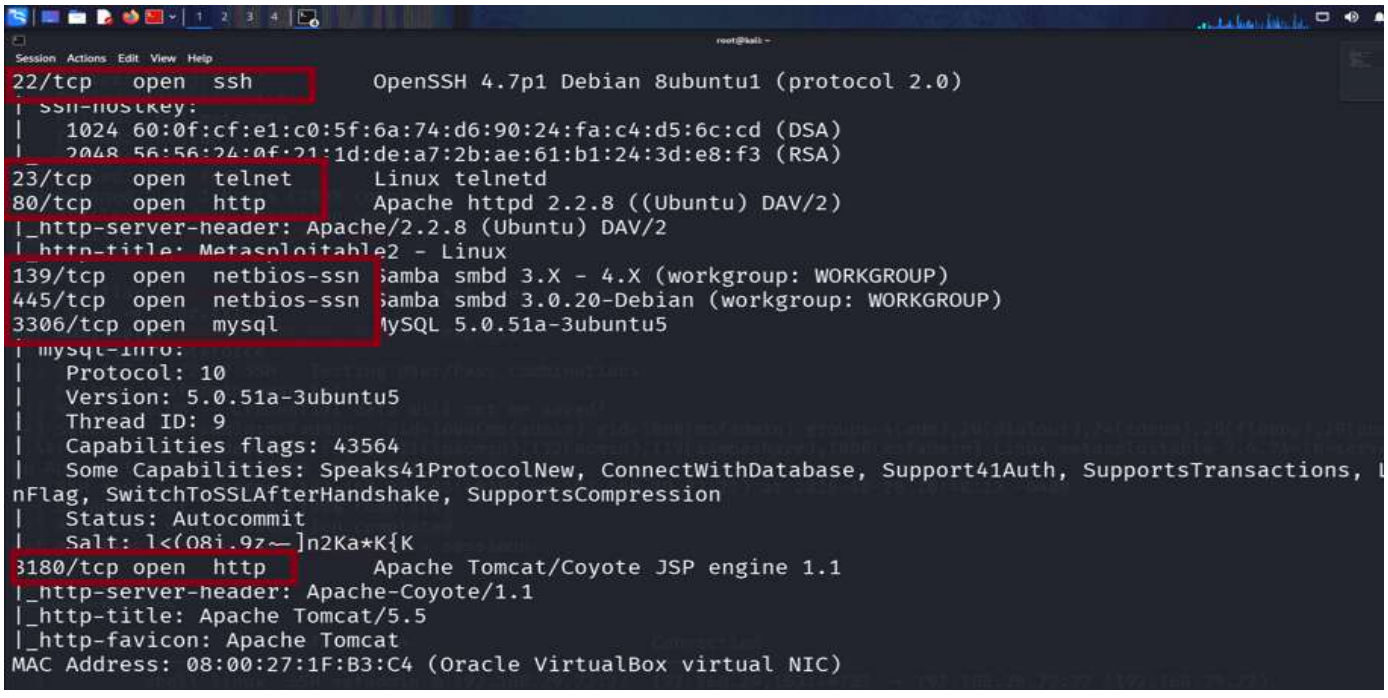
Evidence 05 — Nmap selected-port NSE scan

The nmap -sC -sV command checks selected ports with default NSE scripts and version detection.



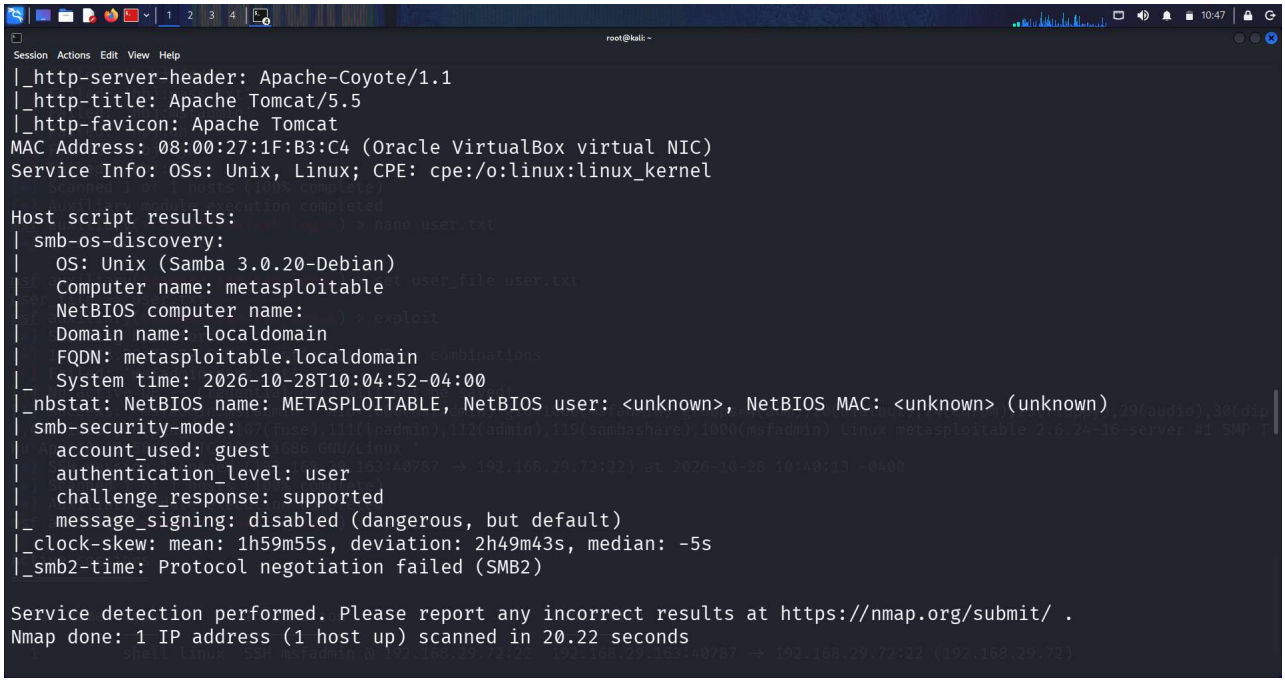
Evidence 06 — FTP and SSH script output

NSE output reports anonymous FTP login allowed and lists SSH host-key fingerprints.



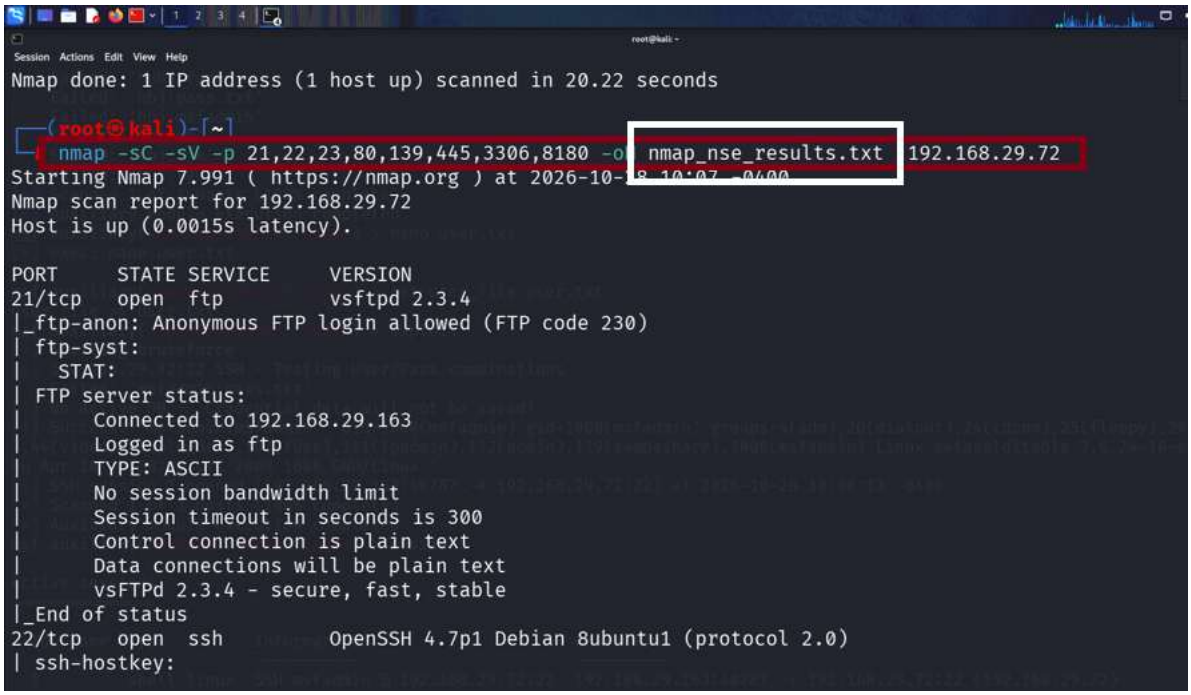
Evidence 07 — HTTP, SMB and database details

NSE output includes Apache/Tomcat and MySQL details; SMB script output reports message signing disabled.



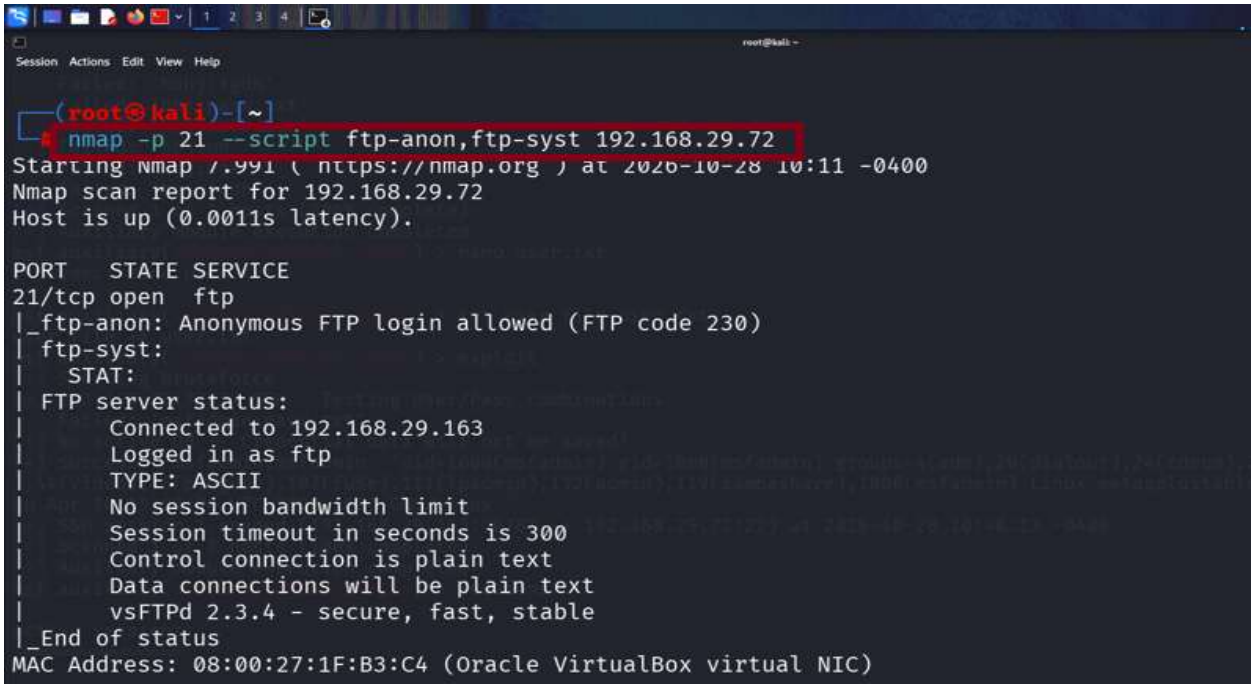
Evidence 08 — Nmap output saved to file

The selected-port scan is saved using -oN to nmap_nse_results.txt, creating a record for the report.



Evidence 09 — Focused FTP NSE checks

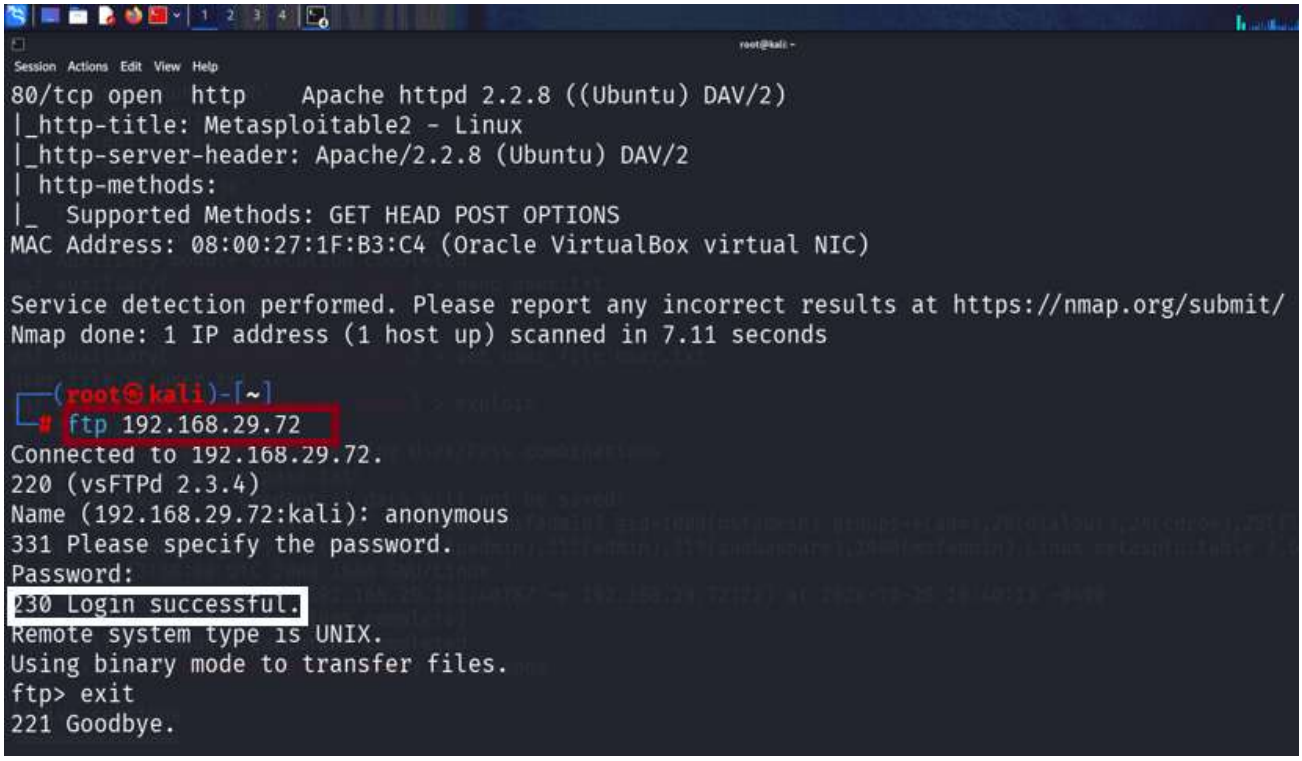
ftp-anon and ftp-syst scripts report anonymous FTP login allowed (FTP code 230) and reveal FTP service information.



Appendix A2 — FTP Login Validation

Evidence 10 — FTP connection validation

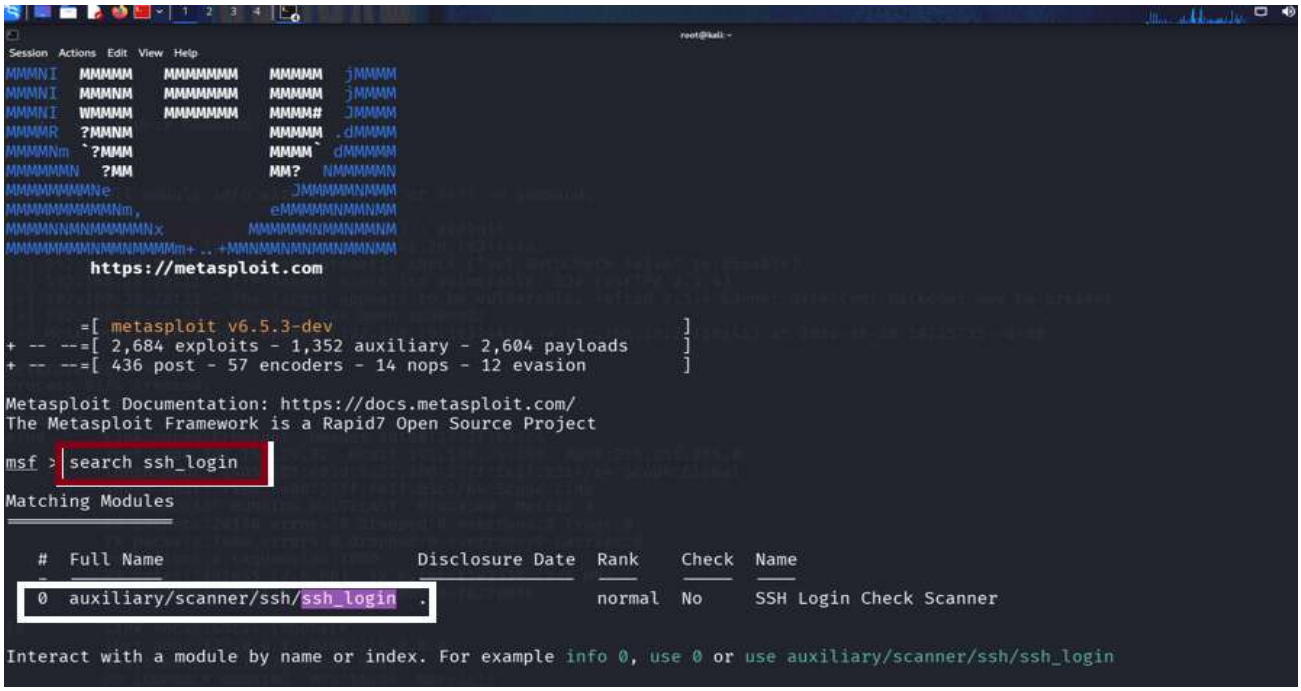
A manual FTP connection succeeds in the lab. This corroborates the FTP finding but is not an Nmap scan.



Appendix A3 — SSH Login Validation

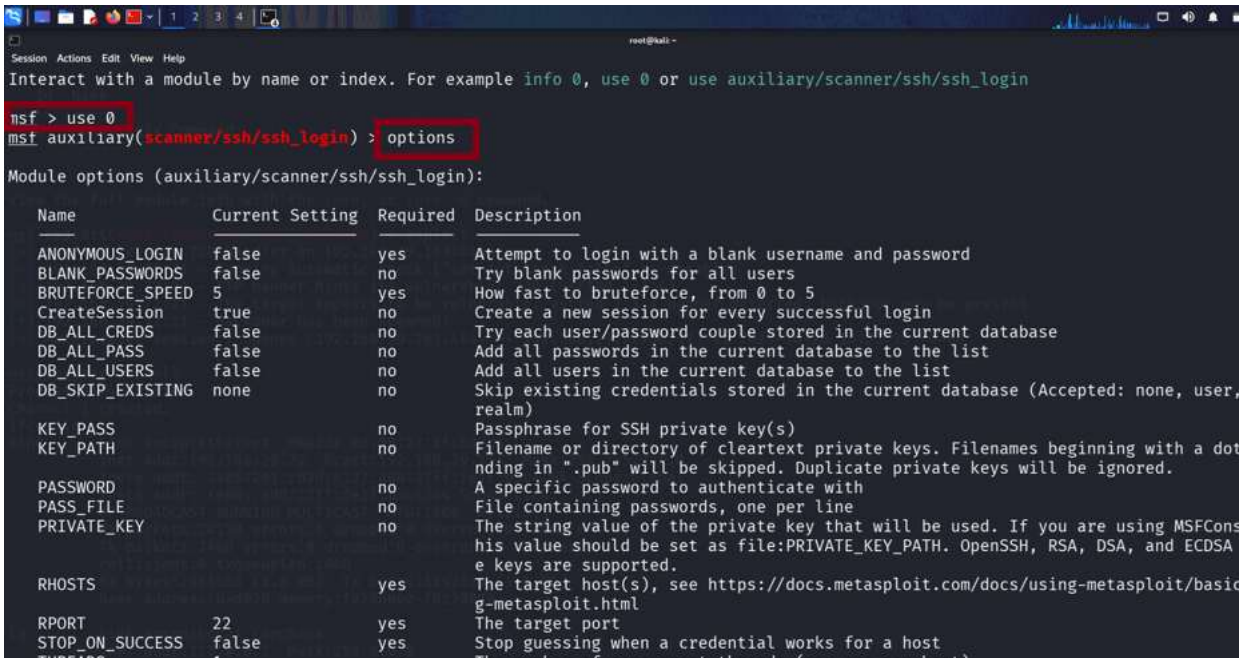
Evidence 11 — Metasploit SSH scanner search

Supporting context only. The search identifies an SSH login scanner module; it is not an Nmap finding.



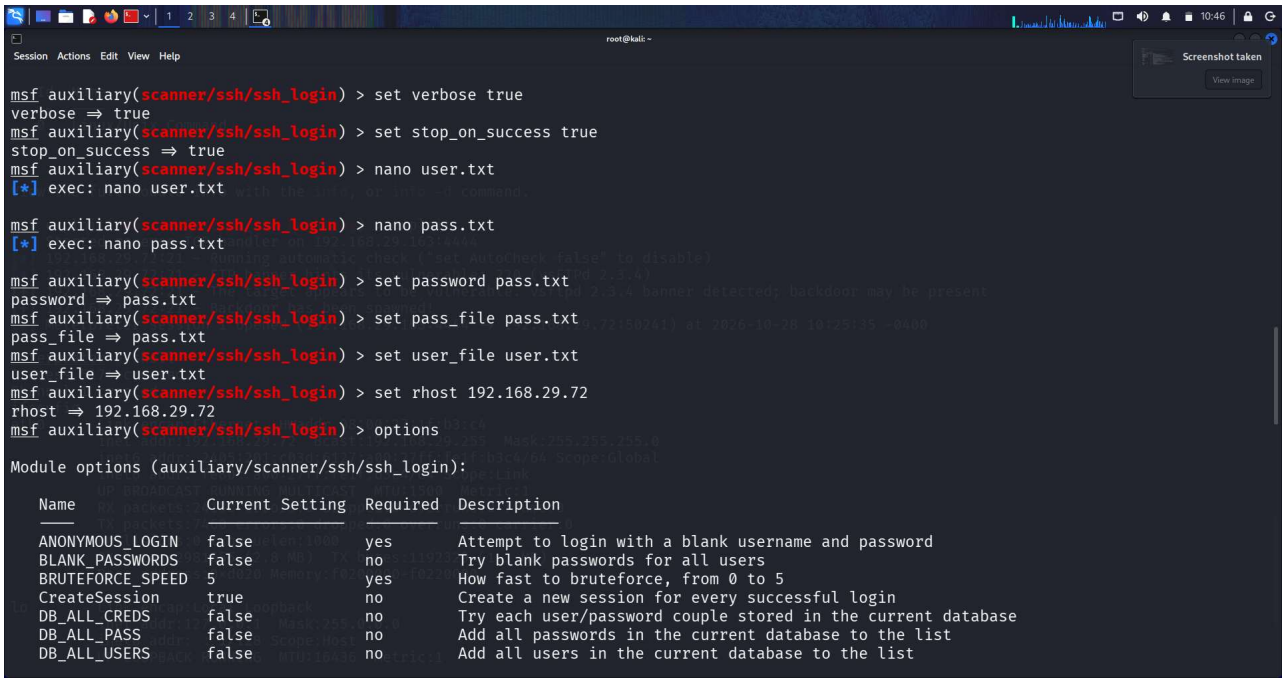
Evidence 12 — SSH scanner options

Shows the module option list and the SSH target port (22). Credential testing is separate from Nmap discovery.



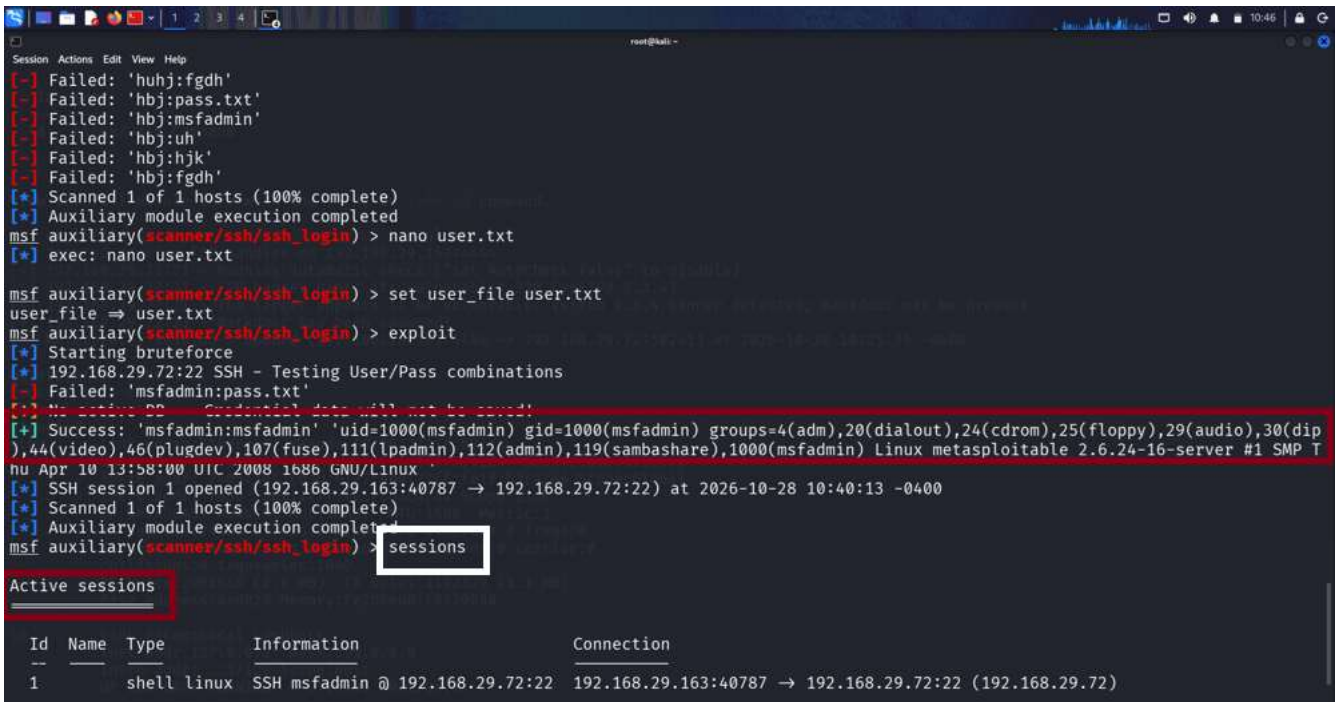
Evidence 13 — SSH scanner configuration

Shows the lab target and local username/password-list settings used in the test.



Evidence 14 — SSH authentication result

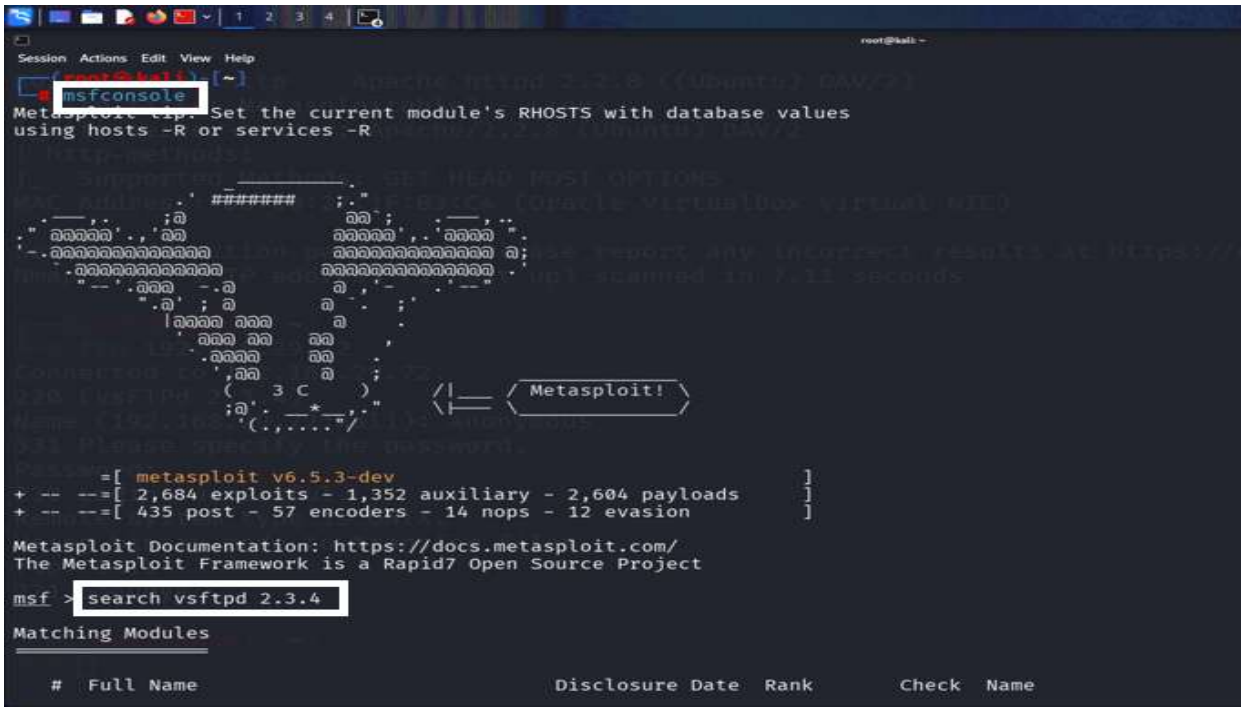
Output shows successful authentication for the lab account msfadmin and an SSH session. Treat as secondary validation evidence.



Appendix A4 — vsftpd Lab Validation

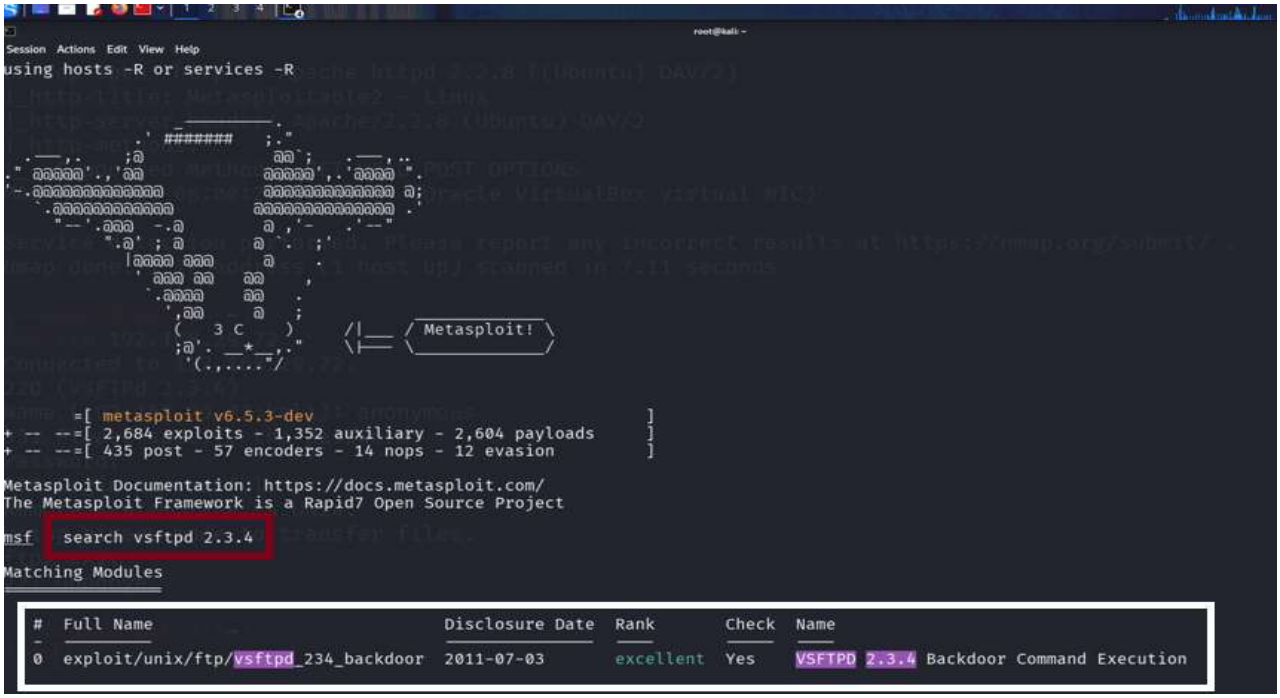
Evidence 15 — Search for vsftpd backdoor module

Metasploit search finds a module associated with vsftpd 2.3.4. Version detection alone is not proof of exploitability.



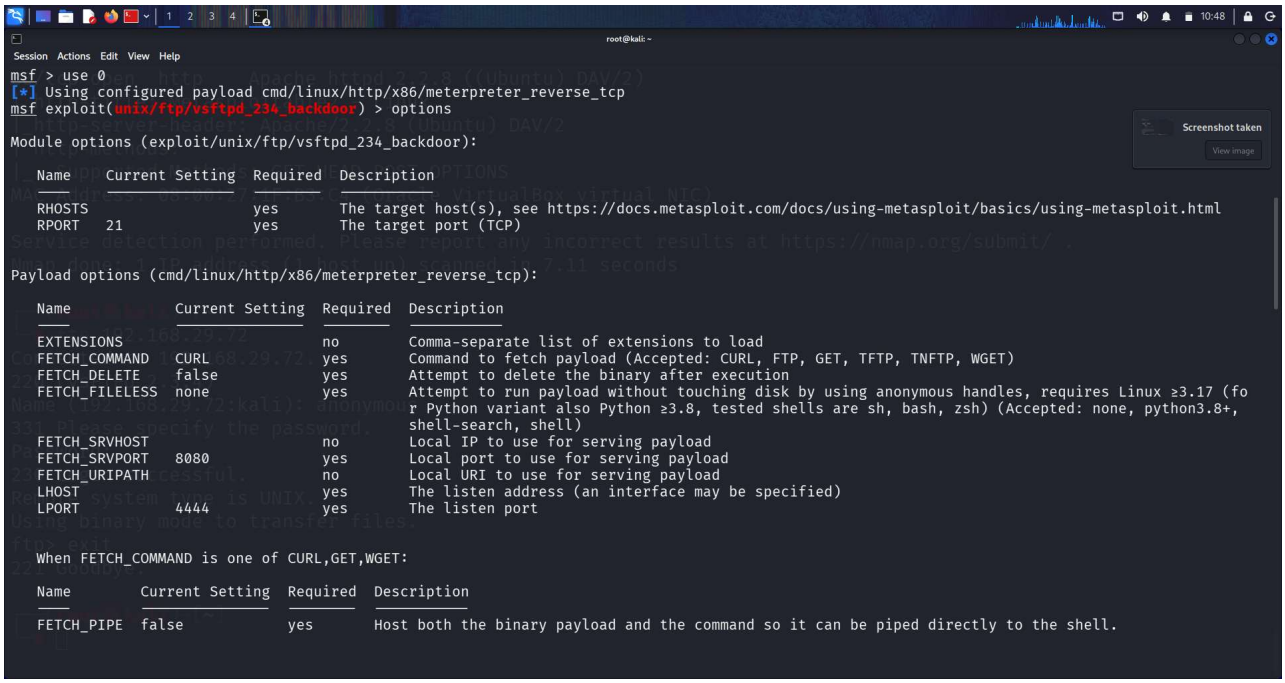
Evidence 16 — vsftpd module options

Shows module and payload options. This is secondary lab validation and should not be confused with Nmap output.



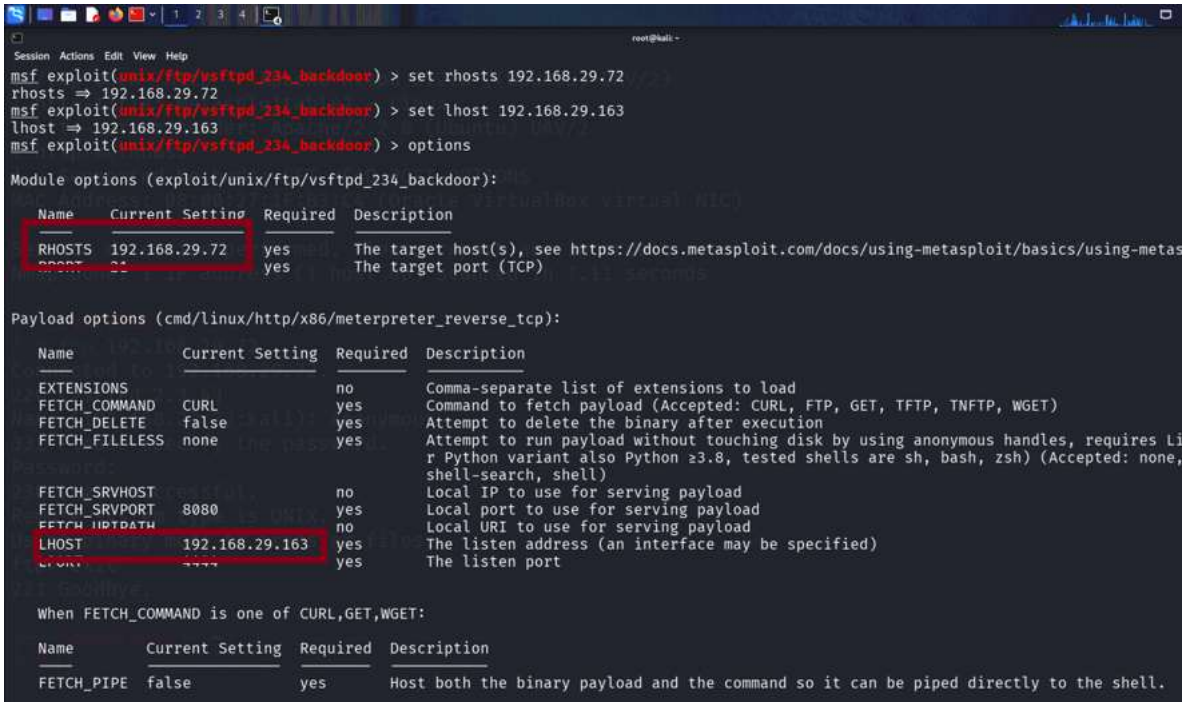
Evidence 17 — Target and callback configuration

Shows target 192.168.29.72 and Kali callback 192.168.29.163 as configured in this lab.



Evidence 18 — vsftpd backdoor session result

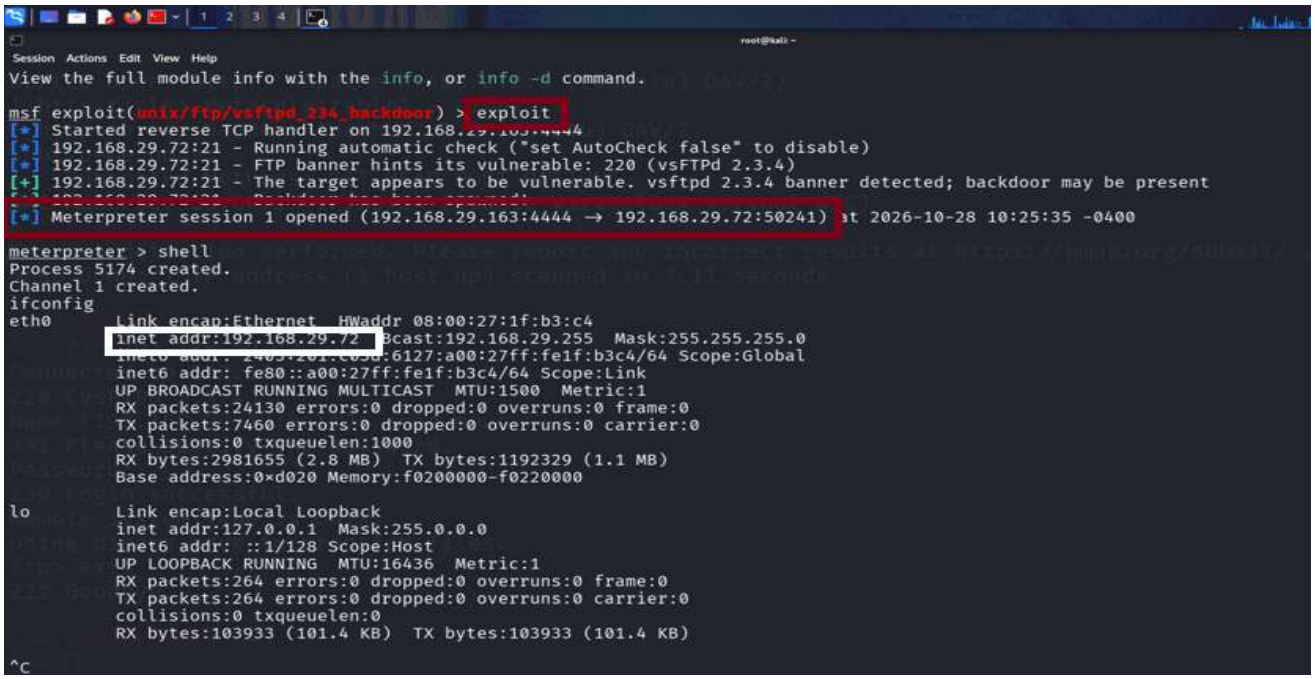
Metasploit reports a backdoor session opened. This validates the known lab weakness; do not run against systems without explicit written authorization.



Appendix A5 — Additional Terminal Evidence

Evidence 19 — Terminal evidence

Additional terminal context from the supplied screenshots, retained as part of the evidence record.



Appendix B — Consolidated Recommendations and Implementation Guide

This section consolidates the recommended corrective actions for the findings in this assessment. The target is an intentionally vulnerable Metasploitable 2 virtual machine used in an isolated training lab. These actions are recommendations for securing a real system; the lab image itself may be designed to remain vulnerable for practice.

B1. Recommended Priority Order

Priority / Finding	Finding	Recommended action	Implementation note
1 — Critical	vsftpd 2.3.4 backdoor exposure (CVE-2011-2523)	Immediately isolate the host; remove the affected package and install a trusted, supported version or rebuild from a trusted image. Treat the host as potentially compromised if the service was reachable outside the lab.	Do not attempt remediation on the intentionally vulnerable training image if you need to preserve it for coursework; snapshot it and work on a separate copy.
2 — High	Default/weak SSH credentials	Change default credentials, remove unnecessary accounts, prefer SSH keys, restrict SSH to a management network, and review authentication logs.	Confirm access remains available before disabling password authentication.
3 — High	Anonymous FTP access	Disable anonymous FTP unless there is a documented business need; check write permissions and exposed files; prefer SFTP or HTTPS for transfers.	Retest anonymous access only on the authorized lab host.
4 — High	Legacy remote administration services	Disable Telnet, rexec, rlogin, and rsh; use SSH with strong authentication instead.	Verify that no required legacy application depends on these services before removal.
5 — High	Unsupported legacy services and software	Upgrade or replace obsolete Apache, OpenSSH, BIND, Samba, MySQL, Tomcat, FTP, and other exposed packages with supported releases. Remove services that are not required.	Version banners alone do not prove the exact patch state; verify package versions and vendor advisories.
6 — Medium / Conditional	Samba configuration and SMB signing	Verify the exact Samba package and configuration. Remove unsafe username-map script settings if present, apply vendor patches, require signing where appropriate, and restrict SMB access.	CVE-2007-2447 applicability is conditional until the required configuration and package status are confirmed.
7 — Medium	Network exposure of databases, RPC, NFS, RMI and admin interfaces	Allow only required source addresses using host and network firewalls; bind services to trusted interfaces; disable unused ports.	Apply least privilege and validate dependencies before closing ports.

B2. Detailed Recommendations by Service

FTP / vsftpd

- If FTP is not required, stop and disable the service and block TCP/21 at the firewall.
- If file transfer is required, migrate to SFTP or HTTPS. If FTP must remain, disable anonymous login, prohibit anonymous write access, restrict client IPs, and use encrypted transport where supported.
- Replace the vulnerable vsftpd 2.3.4 build with a trusted, supported package. Verify package integrity and review system logs for unexpected access.
- Because the supplied lab evidence shows a successful backdoor session, treat a real affected host as potentially compromised: isolate it, preserve relevant logs, rotate credentials from a clean system, and rebuild if integrity cannot be trusted.

SSH

- Change all default or shared passwords, especially the lab-style msfadmin account if it exists on a real system.
- Use unique strong credentials or SSH public-key authentication; disable direct root login and remove unused accounts.
- Restrict TCP/22 to approved management hosts or a VPN, and monitor failed and successful authentication events.
- Retest with Nmap service detection and a separately authorized authentication check; do not put real passwords into report screenshots.

Telnet / rexec / rlogin / rsh

- Disable and uninstall legacy clear-text remote administration services when not required.
- Replace them with SSH and enforce a management-network allowlist.
- Retest the relevant ports (23 and 512–514) to confirm they are closed or filtered.

Samba / SMB

- Verify the installed Samba package version and configuration against the vendor security advisory before concluding a CVE is applicable.
- Upgrade to a supported, patched release; remove unsafe username-map script configuration if present.
- Require SMB signing where appropriate, disable SMBv1 when compatibility permits, and restrict TCP/139 and TCP/445 to trusted systems.
- Retest service exposure and configuration. Do not report CVE-2007-2447 as confirmed solely from a version banner.

Web server / Tomcat

- Replace unsupported Apache 2.2.x and Tomcat 5.5 builds with supported releases; remove unnecessary modules and applications.
- Review HTTP methods and disable methods not required by the application. Apply secure configuration, access controls, and current patches.
- Keep administration consoles private and require strong authentication; restrict TCP/80, TCP/443, and TCP/8180 according to business need.

DNS / BIND

- Upgrade the obsolete BIND version to a supported vendor package.
- Restrict zone transfers to authorized secondary DNS servers and limit recursion to intended clients.
- Review DNS logs and configuration, then validate only the intended DNS ports and services.

Databases / RPC / NFS / RMI

- Upgrade MySQL and any other database software to supported patched versions; remove default accounts and enforce least-privilege database permissions.
- Do not expose database ports (for example, 3306 or 5432) to untrusted networks; restrict them to application hosts.
- Disable unused RPC, NFS, Java RMI registry, and other services. Restrict exports and registry access to trusted hosts.

B3. Nmap-Based Verification and Retest Procedure

Run these commands only against the authorized lab target or a system for which written permission has been granted. After implementing fixes on a separate, approved test system, save the output and compare it with the original evidence.

1. Confirm the host is reachable

```
nmap -sn 192.168.29.72
```

Confirms host discovery only; it does not identify open ports.

2. Recheck TCP ports

```
nmap -sS 192.168.29.72
```

Compare open ports with the baseline. Unneeded services should be closed or filtered.

3. Recheck service banners

```
nmap -sV 192.168.29.72
```

Confirm that exposed services have changed to supported versions where appropriate. Banners are indicators, not definitive patch proof.

4. Check the priority services

```
nmap -sC -sV -p 21,22,23,80,139,445,3306,5432,8180 192.168.29.72
```

Use only where these services are in scope; compare FTP, SSH, SMB, web and database exposure with the baseline.

5. Recheck anonymous FTP

```
nmap -p 21 --script ftp-anon,ftp-syst 192.168.29.72
```

After remediation, anonymous login should no longer be allowed if anonymous FTP was disabled.

6. Save the retest evidence

```
nmap -sV -oN nmap_retest_results.txt 192.168.29.72
```

Keep the output with date, target, tester, changes made and pass/fail notes.

B4. Retest Checklist

☐ Confirm the system owner approved the remediation and retest scope.

☐ Back up configuration and create a VM snapshot before changes.

☐ Apply supported package updates and disable unnecessary services.

☐ Change default credentials and review access permissions.

☐ Apply host/network firewall rules using least privilege.

☐ Re-run the relevant Nmap commands and save the output with timestamps.

☐ Compare before/after results and record each finding as Open, Fixed, Partially Fixed, or Not Applicable.

☐ Attach fresh screenshots and do not reuse old screenshots as proof of remediation.

☐ Document residual risk, owner, due date, and any accepted exceptions.

B5. Reporting and Safety Notes

- The supplied evidence supports the presence of exposed services, anonymous FTP access, and a successful lab-only validation shown in the screenshots. It does not establish that every identified legacy service is exploitable.
- CVE-2011-2523 is associated with the vulnerable vsftpd 2.3.4 backdoor. The reported successful session is evidence from this intentionally vulnerable lab and should not be generalized to other systems without verification.
- CVE-2007-2447 applicability depends on the affected Samba version and configuration; confirm those prerequisites before treating the issue as a confirmed vulnerability.
- CVSS scores should be attributed to the stated CVSS version and source. Where no official CVSS score is established, use a clearly labelled assessor-priority rating rather than presenting it as an official CVSS score.
- No post-remediation scan was included in the supplied evidence. Therefore, the recommendations are proposed actions and the findings should not be marked Fixed until a retest demonstrates the result.
- Metasploitable 2 is intentionally vulnerable. Keep it on an isolated host-only or otherwise restricted virtual network, do not bridge it to an untrusted network, and never use these tests against systems without explicit authorization.

B6. Recommended Final Outcome

For a production system, the preferred outcome is to remove or patch vulnerable software, disable unneeded services, enforce strong authentication, restrict network access, and verify every change with a documented retest. For the SkillLogic training submission, preserve the current screenshots as the baseline evidence, keep remediation recommendations separate from completed fixes, and include new retest screenshots only after a remediation test has actually been performed.